

公開版

ODRE PQC v0.2.9

Public Technical Whitepaper Rev.2

日本語版

2026年9月2日

目次

1. エグゼクティブサマリー
2. 製品目的とアーキテクチャ
3. 暗号プロファイルとセキュリティ契約
4. 脅威モデルと信頼境界
5. 検証・監査証拠
6. クロスプラットフォーム結果
7. Commercial Layerの分離
8. 導入・公開範囲
9. 結論

Document identity

Product	ODRE PQC
Version	0.2.9
Artifact	odre_pqc-0.2.9-py3-none-any.whl
Wheel SHA-256	A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697
Evidence manifest SHA-256	4AF2C88FDEA0CB1FB030E4AB6D5B41394CC52397664364233482E3EC14945F3B
Cryptographic runtime	OpenSSL 3.5.8 / ML-KEM-768 / ML-DSA-65
Verified platforms	Windows Server 2022 AMD64; Ubuntu 24.04.4 LTS AMD64
Core audit verdict	ODRE_PQC_v0.2.9_FULL_DEVSEC_AUDIT_PASS

エグゼクティブサマリー

ODRE PQCは、保護対象FastAPIルートに組み込むポスト量子セキュリティ境界である。小さな統合面の背後で、暗号Runtime管理、認証Session確立、厳格なSequence、Replay耐性、保護された要求・応答意味論、Native Artifact信頼、Lifecycle制御、Fail-Closed強制を統合する。

v0.2.9は本書のSHA-256で識別される封印済みクロスプラットフォームArtifactである。同一WheelがWindows Server 2022 AMD64とUbuntu 24.04.4 LTS AMD64で新規に実行された完全開発セキュリティ監査を通過した。実行範囲内で確認済みCritical・High・Medium製品欠陥は残らなかった。

本書は絶対的安全性ではなく証拠を報告する。PASSは指定Artifact、Platform、構成、脅威モデル、実行試験にのみ適用される。Production導入は別途運用者が管理する判断である。

製品目的とアーキテクチャ

ODRE PQCは選択されたApplicationルートを保護する。TLS、Identity、Authorization、Secure Coding、Host Hardening、Patch、Backup、Monitoringを置き換えない。保護Business HandlerはPQC境界が要求を受理した後のみ実行される。

公開統合モデルは意図的に小さい。初期化、診断、検証、install(app)、Server起動、認証Status確認で構成する。Wire Contractはodre-pqc/3でVersion管理され、OS差分はAdapterとPlatform別Native Runtime Bundle内に留まる。

```
統合フロー: odre-pqc init -> doctor -> verify -> from odre_pqc import install; install(app) -> server start -> odre-pqc status
```

暗号プロファイルとセキュリティ契約

監査RuntimeはOpenSSL 3.5.8 (OpenSSL_version_num 0x30500080) と識別された。実ML-KEM-768、ML-DSA-65 Self-test、Hybrid Handshakeは両対象OSでPASSした。

保護ルートでClassical-onlyへ密かにFallbackしない。Provider、Key Material、Session、Replay State、Native Trust、Runtime Healthが契約を満たさない場合、Business Logic前に保護ルートをBlockする。

Handlerが観測する要求意味論は認証済み内部意味論と一致する。保護応答のStatus、順序付きHeader、Cookie、Bodyは保護Frame内に保持される。Replay、Rollback、Gap、Mismatch、Cross-route、Cross-session曖昧性はFail-Closedで拒否する。

脅威モデルと信頼境界

監査ではNetwork

Tamper、Replay・Concurrency、異常・過大入力、意味論混同、応答Metadata漏えい、Crash/Restart State、Local Filesystem置換、Symlink/Reparse操作、Dependency・Provider Injection、Lifecycle Raceを試験した。

OS、CPU、Python Runtime、承認管理者が完全侵害されていないことを前提とする。悪性Kernel、無制限管理者、物理抽出、Admission後Application Logic侵害、未試験DoS、将来の暗号解読突破への保護は主張しない。

検証・監査証拠

封印Wheelの新規コピーをHash Lock下でInstallし開始・終了Hashが一致した。過去ReportをPASS証拠として再利用せず、監査中に製品Byteを変更しなかった。

静的ReviewはPython 38ファイル・7,160行、Package Metadata、RECORD、Platform Support、両Native Manifest・Archiveを対象とした。Wheel RECORD 45/45 PASS。当時19 Dependencyへの新規Advisory照会はError 0、返却脆弱性Record 0だった。

Metric	Windows	Ubuntu
Platform verdict	PASS	PASS
Replay-race requests	1,280	2,880
Double handler execution	0	0
Native load attempts	3,000	-
Atomic replacements observed	1,062	-
Junction create/remove cycles	3,000	-
Late-promotion parent swaps	-	600 / 600
Untrusted load / object misbinding	0	0
Unresolved Critical / High / Medium	0 / 0 / 0	0 / 0 / 0

クロスプラットフォーム結果

Windows試験はOffline Install、Init、Second-init防止、Doctor、Verify、認証Status、Session遷移、Replay Race、Semantic Binding、ACL Trust、Shutdown Lifetime、Tamper、Crash Recovery、Native Load Stressを含む。

Ubuntu試験はInit、Negative Diagnostics、実PQC、Replay Race、Admission Fuzz、異常・過大入力、HTTP Smuggling形状、応答秘匿、WebSocket Fail-Closed、Native Object Trust、同時Init、Worker Collision、正常・強制Restartを含む。

Commercial Layerの分離

License、Payment、Download、Trial、MonitoringはCommercial Control Planeであり封印v0.2.9暗号Coreではない。Commercial Server Codeは隔離試験102/102、選択JigumON回帰は60/60 PASS。隔離Migration Upgrade-Downgrade-UpgradeもPASSした。

これはProduction導入主張ではない。PostgreSQL Acceptance、Live PayPal、SMTP、Production Secret、Trusted Proxy、配備Customer Helper、End-to-end Client Entitlement Enforcementは完了していない。判定はCode • Isolated Tests PASS、Production NOT READYである。

導入・公開範囲

公式検証環境はWindows Server 2022 AMD64・CPython 3.12.10、Ubuntu 24.04.4 LTS AMD64・CPython 3.12.3。その他Linux、Ubuntu 22.04、Debian 12、ARM64を本証拠で検証済みとは表示しない。

本公開版はPrivate Key、Credential、製品Source、Wheel Byte、Native Binary、Test Harness、Customer Dataを公開しない。内部Reportは非公開維持。独立Source Report未発見の約1.794億Fuzz系譜数値は意図的に主張しない。

結論

ODRE PQC v0.2.9は厳格なFail-Closed契約、実ポスト量子Algorithm、封印済みCross-platform Artifact Identityを小さな統合面で提供する。利用可能証拠は定義範囲で開発セキュリティ監査結果を支持する。

Securityは継続Processである。運用者はArtifact Identityを保持し、Supported Deployment Guidanceに従い、HostとApplicationを維持し、将来変更を新たな証拠義務として扱う必要がある。

公開技術白書 Rev.2 - CoreとCommercialの主張を明示的に分離。